



Barranquilla y Cúcuta - Colombia

P-GT-08

**Procedimiento de Aseguramiento de Servicios
en la Red**

1. OBJETIVO

Este procedimiento describe la manera como la Universidad Simón Bolívar protege la información que es publicada por los servicios, es transmitida y transportada a través de la plataforma de red corporativa, indicando los controles de seguridad que se aplican para acceder a la red cableada e inalámbrica; considerando la privacidad de los estos activos de información como también el uso de registros (logs) que facilitan la trazabilidad y el seguimiento de acciones sospechosas.

2. ALCANCE

Este procedimiento es aplicable a los sistemas de información y servicios informáticos que almacenen y/o transmitan datos de la Universidad Simón Bolívar.

3. DEFINICIONES

- **Cuenta de usuario:** Es el identificador del usuario para ingresar a un a un sistema de información, terminal, o computador personal.
- **Clave de acceso:** Combinación de letras, símbolos y/o números que deben digitarse para obtener acceso a un sistema de información, terminal, o computador personal. Estas llaves si son utilizadas en forma personal, secreta, e intransferible, garantizan una adecuada utilización, resguardo y confiabilidad de la información.
- **Servicios de la plataforma tecnológica:** Todos aquellos servicios controlados por componentes de Tecnologías de la Información y comunicaciones y administrados desde el centro de cómputo de la Entidad.
- **Rol:** Son las funciones que cada usuario tiene que cumplir dentro del sistema.
- **Usuario:** Es una persona que utiliza un sistema o un servicio informático.

4. POLITICAS DE OPERACIÓN

1. Gestión de derechos de acceso privilegiado

- La gestión en la Direccion de TI contempla tres tipos de accesos privilegiados que son:
 - Infraestructura
 - Aplicaciones
 - Bases de Datos
- La asignación de los accesos privilegiados a la plataforma tecnológica en la Direccion de TI hace a través del servicio de Directorio Activo de Microsoft, de la siguiente manera: El director de la Direccion de TI autoriza los derechos de acceso a los servicios de red Microsoft a todos los usuarios de su área al igual que al de las otras dependencias de la Universidad Simón Bolívar de acuerdo con la solicitud de los líderes de los procesos.
- La solicitud de usuarios con derechos de acceso privilegiado de otras áreas distintas a la Direccion de TI debe hacerse mediante la mesa de ayuda/servicios (GLPI) o correo electrónico y/o memorando al Jefe de Direccion de TI y debe ser enviado por Líder de proceso, Jefe de Oficina, o por Secretario General.
- Los sistemas de información deben garantizar la administración de usuarios con perfiles especiales de consulta para auditoría de los sistemas de información.
- En caso de necesitarse un acceso remoto a la infraestructura de la Universidad Simón Bolívar se debe hacer solamente a través del servicio VPN o conexiones SSH, para lo cual se deberá solicitar el apoyo de la Direccion de TI, enunciado la necesidad del acceso y por la duración de este.

2. Gestión de derechos de acceso privilegiado

- La solicitud de claves para la autenticación confidencial de usuarios se gestionará a través de la herramienta de gestión de ti o mesa de ayuda/servicios (GLPI).
- Se debe hacer la transferencia de información confidencial de autenticación de manera segura a los usuarios finales.
- El Directorio activo solicita el cambio de contraseña al primer inicio de sesión al usuario.

3. Revisión de los derechos de acceso de usuarios

- Los administradores de cada sistema de información deben depurar anualmente los usuarios de los sistemas de información de acuerdo con las indicaciones de la Coordinación de Seguridad de la Información de la Universidad Simón Bolívar, el cual deberá comparar y depurar el respectivo listado entregado con el listado de funcionarios activos generado por el área de Talento Humano.

4. Uso de información de autenticación confidencial.

- Los usuarios de los sistemas de información, no deben facilitar sus usuarios o claves de acceso a terceros.

5. DESARROLLO

Nº	Actividad	Tarea	Responsable
1	Instalar el servicio de red	Durante la instalación se debe tener en cuenta que las credenciales por defecto no se deben habilitar y que la(s) credenciales utilizadas deben ser complejas para minimizar el riesgo de password cracking por fuerza bruta. La configuración de rutas, direccionamiento, banners del servicio y otra configuración por defecto debe ser reemplazada.	Coordinación de Redes e Infraestructura Tecnológica
2	Asegurar el servicio de red	Al instalar el nuevo servicio de red sea DHCP, DNS, HTTP, FTP, BASES DE DATOS se debe realizar un hardening de estos buscando configurar las opciones de seguridad disponibles en el servicio como doble factor de autenticación, cifrado, entre otros.	Coordinación de Redes e Infraestructura Tecnológica / Coordinación de Seguridad informática
3	Deshabilitar el acceso remoto	Si no es justificado el acceso remoto para una persona debe deshabilitarse cualquier opción de acceso remoto a la máquina, ya sea por escritorio remoto, aplicaciones de terceros como teamviewer o anydesk, entre otras. En caso de ser necesario se debe configurar los logs y que automáticamente se deshabilite después del tiempo necesario para realizar el trabajo remoto y utilizando protocolo seguros de conexión como SSH nunca TELNET.	Coordinación de Redes e Infraestructura Tecnológica

4	Desactivar servicios innecesarios	Toda instalación nueva requiere una depuración de los servicios y opciones configuradas por defecto ya que muchas de estas son innecesarias y el tenerlas activas conllevan a un mayor nivel de exposición, por lo que se debe inspeccionar en búsqueda de servicios innecesarios. Por ejemplo en una maquina con Windows se debe escribir services.msc en ejecutar y depurar los servicios iniciados y detener los innecesarios	Coordinación de Seguridad informática
5	Habilitar firewall y antimalware	En toda computadora y más aún en los servidores no se debe poner en operación sin que antes se instale el producto antimalware y firewall de la Universidad Simón Bolívar, para esto se debe seguir el procedimiento de protección de código malicioso que acompaña las políticas de seguridad de la información.	Coordinación de Seguridad informática
6	Actualizar el sistema operativo y Apps	Se debe conectar a internet y descargar los últimos parches del sistema operativo y aplicaciones instaladas, para minimizar el numero de vulnerabilidades	Coordinación de Redes e Infraestructura Tecnológica / Coordinación de Seguridad informática
7	Análisis de vulnerabilidades	Realizar test y pruebas de vulnerabilidades que permitan detectar de forma preventiva posibles debilidades.	Coordinación de Seguridad informática
8	Socialización de hallazgos	Se debe socializar con la Coordinación de Redes e Infraestructura tecnológica para la toma de acciones que minimicen la probabilidad de que los fallos sean explotados	Coordinación de Seguridad informática
9	Pruebas operativas y hardening	Estas pruebas están destinadas a comprobar el correcto funcionamiento del servicio	Coordinación de Redes e Infraestructura Tecnológica
10	Puesta en marcha del servicio	El coordinador de seguridad de la información da visto bueno para la puesta en marcha del servicio, y el coordinador de infraestructura habilita el servicio para el uso de los usuarios correspondientes	Coordinación de Redes e Infraestructura Tecnológica

6. BIBLIOGRAFÍA:

- ISO/IEC 27002, Information Technology. Security Techniques. Code of practice for information security controls.
- NTC ISO-22301:2012 Continuidad de Negocio. Sistemas de gestión de Continuidad de Negocio. Requisitos.
- NTC ISO-IEC 27001:2013 Tecnología de la Información. Técnicas de Seguridad. Sistemas de Gestión de la Seguridad de la Información Requisitos.
- Guía: Controles de Seguridad y Privacidad de la Información, MINTIC.